

Cyber Threat Intelligence

Executive Briefing

Report Date: July 06, 2026

Generated: 2026-07-06 11:18 UTC | Classification: TLP:AMBER

Prepared by: Auto-CTI Autonomous Threat Intelligence Pipeline

1. Risk Statistics Summary

Critical	High	Medium	Low	Total
4	11	3	2	20

2. Executive Summary

As of July 06, 2026, the security intelligence unit has concluded an assessment of 20 identified vulnerabilities, categorized as 4 Critical, 11 High, 3 Medium, and 2 Low. The current organizational risk posture remains elevated, characterized by an overall CVSS v3.1 severity rating of High, necessitating immediate remediation efforts to prevent potential exploitation of sensitive internal assets. CVE-2026-49360, Unauthenticated SQL Execution in Recce Server, represents the highest priority threat due to the absence of input sanitization, which facilitates direct, unauthenticated database manipulation. We recommend an aggressive, prioritized patching schedule and the immediate implementation of compensatory controls to mitigate the exploitability of these flaws. The organization must adopt a posture of immediate defensive readiness to address these identified attack surfaces within the mandated timelines.

3. Critical Action List

- CVE-2026-49360: Execute emergency patching and enable input validation controls on all Recce Server instances within 24 hours.
- CVE-2026-49352: Initiate immediate revocation and rotation of all JWT authentication secrets across the 9router application infrastructure within 24 hours.
- CVE-2026-54617: Deploy firewall-level traffic filtering to block unauthorized access to the LaunchServer FileServerHandler within 24 hours.
- CVE-2026-52830: Isolate the fast-mcp-telegram component from public network access and apply vendor-provided patches within 48 hours.
- CVE-2026-50194: Reconfigure Steeltoe management port isolation policies to block unauthorized access attempts within 72 hours.

4. Quick Reference: All Identified Vulnerabilities

CVE ID	Finding Name	CVSS	Severity	Urgency	CWE
CVE-2026-49360	Unauthenticated SQL Execution in ...	9.8	Critical	88/100	CWE-73
CVE-2026-49352	Authentication Bypass via Hardcod...	9.8	Critical	88/100	CWE-798
CVE-2026-54617	Path Traversal in LaunchServer Fi...	9.8	Critical	88/100	CWE-22
CVE-2026-52830	Bearer Token Path Traversal in Te...	9.4	CRITICAL	85/100	CWE-22
CVE-2026-50194	Management Port Isolation Bypass ...	8.2	HIGH	74/100	CWE-288
CVE-2026-2092	Improper Validation of Encrypted ...	7.7	HIGH	69/100	CWE-1287
CVE-2026-49353	Local Access Gate Bypass via Host...	7.5	High	68/100	CWE-290
CVE-2026-46599	Resource Exhaustion in TIFF PackB...	7.5	High	68/100	CWE-770
CVE-2026-52792	Source Disclosure via NTFS Filena...	7.5	High	68/100	CWE-69
CVE-2026-50200	Database Password Leakage in Envi...	7.5	HIGH	68/100	CWE-200
CVE-2026-50196	Eureka Registry Poisoning via Dat...	7.5	HIGH	68/100	CWE-20
CVE-2026-49289	Denial of Service via XPath Trans...	7.5	High	68/100	CWE-400
CVE-2026-52829	Mempool Corruption in Zebra Addre...	7.5	High	68/100	CWE-617
CVE-2026-52834	Integer Overflow in jxl-grid on 3...	7.3	High	66/100	CWE-122
CVE-2026-49284	Improper Validation of SAML Respo...	7.1	High	64/100	CWE-345
CVE-2026-50201	Insufficient Restriction on Sensi...	6.5	MEDIUM	59/100	CWE-269
CVE-2026-50202	Static JWKS Cache Poisoning in St...	5.9	MEDIUM	53/100	CWE-668
CVE-2026-50267	Insecure Storage of TLS Private K...	4.7	MEDIUM	42/100	CWE-312
CVE-2026-49292	Improper Access Control on Initia...	3.7	Low	28/100	CWE-862
CVE-2026-50268	Insecure Padding Configuration in...	1.9	LOW	12/100	CWE-256

5. Detailed Vulnerability Findings

CVE-2026-49360

Finding: Unauthenticated SQL Execution in Recce Server

CVSS v3.1 Score: 9.8 | Severity: Critical | Urgency Score: 88/100 | CWE: CWE-73

Score Provenance: Verified

MITRE ATT&CK: T1190, T1505

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	High

Description:

The Recce server component fails to sanitize input within its database interaction layer, leading to improper query execution via DuckDB. The vulnerability originates from a lack of authentication checks on interface handlers that

facilitate file system operations. An unauthenticated attacker can achieve arbitrary file read and write access, compromising system-wide data integrity and confidentiality.

Proof of Concept (PoC):

An unauthenticated remote attacker identifies the exposed Recce management endpoint. The attacker sends a crafted POST request containing a malicious SQL string targeting the DuckDB interface. The server process executes the underlying SQL, allowing the attacker to manipulate local files on the host filesystem. This results in full compromise of the application data and underlying host configuration.

CVE-2026-49352

Finding: Authentication Bypass via Hardcoded JWT Secret

CVSS v3.1 Score: 9.8 | Severity: Critical | Urgency Score: 88/100 | CWE: CWE-798

Score Provenance: Verified

MITRE ATT&CK: T1552, T1190

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	High

Description:

The 9router application uses a hardcoded fallback JWT secret in its authentication component, which fails to rotate when the production configuration is absent. The root cause is the inclusion of static, predictable cryptographic keys within the source code base. This allows an unauthenticated attacker to forge valid JWT tokens, effectively bypassing all authentication controls.

Proof of Concept (PoC):

An unauthenticated remote attacker identifies the hardcoded JWT secret used by the 9router authentication service. The attacker generates a signed JWT payload using the discovered secret to impersonate a privileged administrator. The server accepts this forged token as legitimate, granting the attacker full unauthorized access to all backend resources.

CVE-2026-54617

Finding: Path Traversal in LaunchServer File Handler

CVSS v3.1 Score: 9.8 | Severity: Critical | Urgency Score: 88/100 | CWE: CWE-22

Score Provenance: Verified

MITRE ATT&CK: T1005, T1190

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	High

Description:

The LaunchServer FileServerHandler contains an unauthenticated path traversal vulnerability that allows access to files outside the intended web root. This occurs because the handler fails to sanitize user-provided file path inputs before accessing the local disk. An unauthenticated attacker can read arbitrary files from the server's local file system.

Proof of Concept (PoC):

An unauthenticated remote attacker sends a GET request to the file server handler using a path argument like /files/..%2f..%2fetc/passwd. The server resolves the relative path without validation, effectively escaping the intended directory sandbox. The attacker then retrieves the contents of the target sensitive system file.

CVE-2026-52830

Finding: Bearer Token Path Traversal in Telegram Sessions

CVSS v3.1 Score: 9.4 | Severity: CRITICAL | Urgency Score: 85/100 | CWE: CWE-22

Score Provenance: Verified

MITRE ATT&CK: T1005, T1552

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:L

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	Low

Description:

The fast-mcp-telegram component suffers from a path traversal vulnerability in its bearer token handling mechanism that circumvents session protection. The error occurs because the token processing logic allows filesystem navigation characters to manipulate file path lookups for session files. This allows an unauthenticated attacker to read or hijack arbitrary Telegram session data.

Proof of Concept (PoC):

An unauthenticated attacker crafts a request using a path-traversal payload as the bearer token header. The application treats the path-traversal string as a session filename, bypassing the directory restriction for reserved Telegram sessions. The system reads the referenced session data, granting the attacker access to legitimate Telegram session state.

CVE-2026-50194

Finding: Management Port Isolation Bypass in Steeltoe

CVSS v3.1 Score: 8.2 | Severity: HIGH | Urgency Score: 74/100 | CWE: CWE-288

Score Provenance: Verified

MITRE ATT&CK: T1133, T1036

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	Low

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	None

Description:

Steeltoe fails to enforce strict management-port isolation, allowing attackers to reach internal management endpoints via spoofed Host headers. The issue arises from the application's reliance on header inspection rather than network-level isolation to separate management traffic. An attacker can access sensitive management ports remotely, potentially gaining access to internal monitoring and administrative APIs.

Proof of Concept (PoC):

An unauthenticated attacker targets the application's management endpoint by spoofing the Host header to appear as an internal administrative interface. The application's security middleware misinterprets the request as an internal-only access attempt and permits it. The attacker then successfully accesses internal configuration endpoints, potentially modifying service settings.

CVE-2026-2092

Finding: Improper Validation of Encrypted SAML Assertions

CVSS v3.1 Score: 7.7 | Severity: HIGH | Urgency Score: 69/100 | CWE: CWE-1287

Score Provenance: Verified

MITRE ATT&CK: T1550

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:H/PR:L/UI:N/S:C/C:H/I:L/A:L

Attack Vector	Network
Privileges Required	Low
Scope	Changed
Integrity Impact	Low

Attack Complexity	High
User Interaction	None
Confidentiality Impact	High
Availability Impact	Low

Description:

Keycloak fails to correctly validate encrypted SAML assertions, leading to unauthorized access. The issue stems from insufficient checking of the underlying cryptographic signatures or decryption integrity before trust is established. This flaw allows an authenticated user to manipulate the assertion in a way that elevates privileges or bypasses security checks.

Proof of Concept (PoC):

An authenticated user with low privileges intercepts their SAML login response. The user modifies the encrypted assertion body to include unauthorized attributes that Keycloak fails to re-validate post-decryption. Keycloak processes the assertion and grants the user elevated privileges or access to unauthorized application scopes.

CVE-2026-49353

Finding: Local Access Gate Bypass via Host Header

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 68/100 | CWE: CWE-290

Score Provenance: Verified

MITRE ATT&CK: T1133, T1036

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N

Attack Vector	Network
Privileges Required	None

Attack Complexity	Low
User Interaction	None

Scope	Unchanged
Integrity Impact	None

Confidentiality Impact	High
Availability Impact	None

Description:

The 9router application exhibits an incomplete patch regarding internal access control gates, specifically failing to validate the Host header correctly. The root cause is a reliance on unauthenticated header inputs to determine origin legitimacy for restricted internal paths. An unauthenticated attacker can spoof the Host header to access administrative endpoints intended for local loopback communication only.

Proof of Concept (PoC):

An unauthenticated remote attacker targets the 9router gateway service. The attacker modifies the HTTP 'Host' header to 'localhost' while requesting a protected administrative endpoint. The application logic incorrectly validates the request origin, bypassing the local-only restriction. The attacker then gains access to sensitive internal configuration pages.

CVE-2026-46599**Finding: Resource Exhaustion in TIFF PackBits Decompression**

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 68/100 | CWE: CWE-770

Score Provenance: Verified

MITRE ATT&CK: T1499

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	None
Availability Impact	High

Description:

The golang.org/x/image/tiff library exhibits excessive resource consumption during the decompression of maliciously crafted PackBits encoded image data. The vulnerability stems from a lack of input size validation before allocating memory or processing loop logic for high-compression ratios. This permits a remote attacker to cause a denial-of-service condition by exhausting system memory resources.

Proof of Concept (PoC):

An unauthenticated remote attacker uploads a specially crafted TIFF image containing highly compressed PackBits data. The TIFF processing engine enters an unbounded memory allocation loop upon attempting to decompress the malformed image chunk. This results in immediate exhaustion of available system memory, leading to a process crash or service unavailability.

CVE-2026-52792**Finding: Source Disclosure via NTFS Filename Mappings**

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 68/100 | CWE: CWE-69

Score Provenance: Verified

MITRE ATT&CK: T1005, T1552

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	None

Description:

The Algernon server allows disclosure of server-side script source code on Windows platforms due to improper handling of specific NTFS naming conventions. The vulnerability results from the web server engine not canonicalizing paths before checking file access permissions. An attacker can retrieve sensitive source code files, leading to potential intellectual property or credential exposure.

Proof of Concept (PoC):

An unauthenticated remote attacker accesses the Algernon server with a request using an NTFS-specific filename format (e.g., using trailing spaces or special characters). The server fails to process the request as a non-executable resource and proceeds to stream the file contents directly to the attacker. This exposes the raw source code of the underlying application scripts.

CVE-2026-50200

Finding: Database Password Leakage in Environment Sanitizer

CVSS v3.1 Score: 7.5 | Severity: HIGH | Urgency Score: 68/100 | CWE: CWE-200

Score Provenance: Verified

MITRE ATT&CK: T1552

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	None

Description:

The Steeltoe environment sanitizer fails to filter database connection strings, causing embedded passwords to leak in status output. The vulnerability is caused by an incomplete sanitization list that excludes specific, non-standard connection string formats. This results in the exposure of cleartext database credentials to any unauthenticated observer of the environment status page.

Proof of Concept (PoC):

An unauthenticated remote attacker accesses the application's configuration actuator endpoint. The attacker observes that the environment display contains a database connection string containing a cleartext password. Because the sanitizer regex failed to match the connection string, the attacker successfully retrieves credentials for the backend database.

CVE-2026-50196

Finding: Eureka Registry Poisoning via DataCenterInfo

CVSS v3.1 Score: 7.5 | Severity: HIGH | Urgency Score: 68/100 | CWE: CWE-20

Score Provenance: Verified

MITRE ATT&CK: T1499

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

Attack Vector	Network	Attack Complexity	Low
Privileges Required	None	User Interaction	None
Scope	Unchanged	Confidentiality Impact	None
Integrity Impact	None	Availability Impact	High

Description:

The Steeltoe.Discovery.Eureka client is vulnerable to registry poisoning when an unrecognized DataCenterInfo.Name is processed, disrupting service registry fetches. The root cause is a failure in the client to safely handle unexpected or malformed registry metadata. This allows an attacker to deny service to other components relying on Eureka for service discovery.

Proof of Concept (PoC):

An attacker registers a malicious service instance with the Eureka registry using a crafted 'DataCenterInfo.Name' attribute. When the Steeltoe client fetches the service registry update, it hits an unhandled exception while parsing the field. The client's registry processing stops entirely, leading to a service discovery outage for the entire cluster.

CVE-2026-49289

Finding: Denial of Service via XPath Transformation

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 68/100 | CWE: CWE-400

Score Provenance: Verified

MITRE ATT&CK: T1499

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

Attack Vector	Network	Attack Complexity	Low
Privileges Required	None	User Interaction	None
Scope	Unchanged	Confidentiality Impact	None
Integrity Impact	None	Availability Impact	High

Description:

SimpleSAMLphp is susceptible to a denial-of-service attack via maliciously constructed XPath transforms within SAML metadata. The issue is caused by recursive or overly complex XPath expressions that consume excessive CPU and memory during processing. This allows an attacker to crash the SAML processing engine or cause significant latency issues.

Proof of Concept (PoC):

An attacker uploads a SAML metadata file containing highly nested and recursive XPath transformation expressions. The SimpleSAMLphp XML processing engine attempts to evaluate these transformations, resulting in extreme resource usage. The application's server resources are exhausted, resulting in a denial of service to all valid SAML login attempts.

CVE-2026-52829

Finding: Mempool Corruption in Zebra Address Book

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 68/100 | CWE: CWE-617

Score Provenance: Verified

MITRE ATT&CK: T1499

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	None
Availability Impact	High

Description:

The Zebra Address Book experiences mempool misbehavior during IPv4-mapped address handling, leading to application abortion. The root cause is an improper bounds calculation when translating address families, which causes illegal memory writes. This results in an immediate process abort, effectively disabling the address book lookup service for users.

Proof of Concept (PoC):

An attacker sends a specifically formatted request containing an IPv4-mapped address to the Zebra Address Book service. The application's network stack attempts to handle the address format, but an internal buffer index wraps around during allocation. This state triggers a safety abort mechanism (assert failure) to prevent memory corruption, rendering the service offline.

CVE-2026-52834

Finding: Integer Overflow in jxl-grid on 32-bit Systems

CVSS v3.1 Score: 7.3 | Severity: High | Urgency Score: 66/100 | CWE: CWE-122

Score Provenance: Verified

MITRE ATT&CK: T1210

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	Low

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	Low
Availability Impact	High

Description:

The jxl-grid library suffers from an out-of-bounds write vulnerability on 32-bit platforms due to integer overflow during dimension calculations. The root cause is a lack of bounds checking on input parameters used to allocate or index grid buffers. This can lead to memory corruption, allowing an attacker to achieve arbitrary code execution or cause process instability.

Proof of Concept (PoC):

An attacker provides a malformed image input containing dimensions that trigger an integer overflow in the grid-processing routines. The application allocates insufficient heap memory based on the overflowed size result, leading to out-of-bounds memory writes during data population. This corruption can eventually lead to control flow

hijacking on the 32-bit platform.

CVE-2026-49284

Finding: Improper Validation of SAML Response Assertions

CVSS v3.1 Score: 7.1 | Severity: High | Urgency Score: 64/100 | CWE: CWE-345

Score Provenance: Verified

MITRE ATT&CK: T1550

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:H/I:H/A:N

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	Required
Confidentiality Impact	High
Availability Impact	None

Description:

The SimpleSAMLphp Service Provider incorrectly accepts assertions when an unsigned `Response/InResponseTo` element is paired with a signed assertion missing the `SubjectConfirmationData/InResponseTo` field. This arises from a flawed logic validation chain that allows one element to implicitly satisfy the authenticity of the other. An attacker can perform a SAML response injection attack, leading to potential account impersonation.

Proof of Concept (PoC):

An attacker creates a malicious SAML assertion lacking the expected `InResponseTo` parameter. The attacker injects this into a target user's browser session via a manipulated SAML response. SimpleSAMLphp incorrectly validates the signature of the assertion and ignores the missing response linkage, allowing the attacker to be authenticated as the victim user.

CVE-2026-50201

Finding: Insufficient Restriction on Sensitive Actuators

CVSS v3.1 Score: 6.5 | Severity: MEDIUM | Urgency Score: 59/100 | CWE: CWE-269

Score Provenance: Verified

MITRE ATT&CK: T1068, T1592

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:N/A:N

Attack Vector	Network
Privileges Required	Low
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	None

Description:

Steeltoe's management actuators, such as heapdump and environment info, are only protected by a restrictive privilege level that is too easily bypassed. The root cause is improper authorization logic in the actuator filter chain. This allows authenticated users with standard application roles to view sensitive server heap dumps and environment configurations.

Proof of Concept (PoC):

An authenticated user with low privileges requests the /actuator/heapdump endpoint. The system checks the user's permissions and incorrectly grants access because the role check is too broad. The user successfully downloads the heap memory dump, which may contain sensitive secrets and application data.

CVE-2026-50202

Finding: Static JWKS Cache Poisoning in Steeltoe

CVSS v3.1 Score: 5.9 | Severity: MEDIUM | Urgency Score: 53/100 | CWE: CWE-668

Score Provenance: Verified

MITRE ATT&CK: T1496

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:H/PR:H/UI:N/S:U/C:H/I:H/A:N

Attack Vector	Network	Attack Complexity	High
Privileges Required	High	User Interaction	None
Scope	Unchanged	Confidentiality Impact	High
Integrity Impact	High	Availability Impact	None

Description:

Steeltoe uses a static JWKS cache that is shared across different authentication schemes and never properly invalidated. The root cause is a lack of cache partitioning and logic for handling key rotation updates. This allows an attacker to induce service-wide authentication failure or potentially bypass validation if they can influence the initial cache population.

Proof of Concept (PoC):

A high-privileged attacker manipulates the JWKS endpoint configuration used by the application to point to an attacker-controlled source. The Steeltoe application caches the malicious JWKS payload indefinitely. Future authentication attempts are validated against this poisoned cache, compromising the trust of the authentication system.

CVE-2026-50267

Finding: Insecure Storage of TLS Private Keys

CVSS v3.1 Score: 4.7 | Severity: MEDIUM | Urgency Score: 42/100 | CWE: CWE-312

Score Provenance: Verified

MITRE ATT&CK: T1552

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:L/AC:H/PR:L/UI:N/S:U/C:H/I:N/A:N

Attack Vector	Local	Attack Complexity	High
Privileges Required	Low	User Interaction	None
Scope	Unchanged	Confidentiality Impact	High
Integrity Impact	None	Availability Impact	None

Description:

Steeltoe writes TLS private keys to the /tmp directory with insecure permissions and fails to delete them after use. The root cause is a poor handling of temporary file lifecycles and permission sets during key lifecycle management. This enables local attackers with read access to potentially compromise long-lived TLS private keys.

Proof of Concept (PoC):

A local user with low privileges monitors the /tmp directory while the Steeltoe application restarts or performs TLS handshake initialization. The application writes sensitive key material to a predictable file name in /tmp. The attacker reads the file contents before the application cleans up, gaining access to the plaintext private key.

CVE-2026-49292

Finding: Improper Access Control on Initialization Endpoint

CVSS v3.1 Score: 3.7 | Severity: Low | Urgency Score: 28/100 | CWE: CWE-862

Score Provenance: Verified

MITRE ATT&CK: T1068

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:L/A:L

Attack Vector	Network	Attack Complexity	High
Privileges Required	None	User Interaction	None
Scope	Unchanged	Confidentiality Impact	Low
Integrity Impact	Low	Availability Impact	Low

Description:

The Kiwi TCMS /init-db/ interface fails to verify if the initial database setup phase has already been completed. The root cause is a missing authentication check that persists after the application's first-use lifecycle. This allows an attacker to interact with the database initialization interface, potentially exposing or modifying application state.

Proof of Concept (PoC):

An unauthenticated remote attacker browses to the /init-db/ endpoint of an existing Kiwi TCMS deployment. The application renders the page despite the database already being configured for production use. The attacker interacts with these settings, potentially triggering internal state changes that compromise the application installation.

CVE-2026-50268

Finding: Insecure Padding Configuration in Steeltoe

CVSS v3.1 Score: 1.9 | Severity: LOW | Urgency Score: 12/100 | CWE: CWE-256

Score Provenance: Verified

MITRE ATT&CK: T1552

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:L/AC:H/PR:H/UI:N/S:U/C:L/I:N/A:N

Attack Vector	Local	Attack Complexity	High
Privileges Required	High	User Interaction	None
Scope	Unchanged	Confidentiality Impact	Low
Integrity Impact	None	Availability Impact	None

Description:

Steeltoe's OAEP implementation silently reverts to PKCS#1 v1.5 padding when encryption settings are misconfigured. The root cause is a failure in the cryptographic configuration provider to enforce strict padding requirements. This allows an attacker to potentially conduct padding oracle attacks if they can intercept and observe timing patterns in the encryption process.

Proof of Concept (PoC):

A local attacker with high privileges inspects the Steeltoe application's cryptographic configuration. The attacker manually alters the padding scheme, causing the application to fallback to the insecure PKCS#1 v1.5 mode. The attacker then monitors error responses to attempt a Bleichenbacher-style padding oracle attack on encrypted tokens.

6. Methodology & Data Sources

This report was generated by the Auto-CTI Autonomous Cyber Threat Intelligence Pipeline, an automated multi-agent system designed to simulate a real-world Security Operations Center (SOC) workflow. The pipeline operates in three sequential stages: (1) the Scout Agent collects the latest CVE disclosures from NVD, the GitHub Advisory Database, and OSV.dev, cross-referencing active threat pulses via AlienVault OTX; (2) the Triage Agent performs structured analysis using the CVSS v3.1 scoring standard, assigns CWE root-cause classifications, maps each vulnerability to relevant MITRE ATT&CK techniques, and computes a composite Urgency Score; (3) the Publisher Agent synthesizes the triaged data into this executive briefing. Every CVSS score is tagged with a Score Provenance label indicating whether it was confirmed against an official database (NVD or CNA record) or estimated by the analysis model when no official score existed. All CVE identifiers, CVSS scores, and CWE mappings are independently verifiable via the references provided in Section 5. References marked 'Fallback Search' indicate the specific CVE record was not found live at NVD or CVE.org at generation time; a source-database search link is provided instead. Severity classification follows the CVSS v3.1 standard: Critical (9.0-10.0), High (7.0-8.9), Medium (4.0-6.9), Low (0.1-3.9).

Primary Data Sources:

- NIST National Vulnerability Database (NVD) -- <https://nvd.nist.gov/>
- GitHub Advisory Database -- <https://github.com/advisories>
- OSV.dev Open Source Vulnerabilities -- <https://osv.dev/>
- CVE Services API (MITRE CNA Records) -- <https://cveawg.mitre.org/>
- OpenCVE -- <https://www.opencve.io/>
- AlienVault Open Threat Exchange (OTX) -- <https://otx.alienvault.com/>
- MITRE ATT&CK Framework -- <https://attack.mitre.org/>
- CVSS v3.1 Specification -- <https://www.first.org/cvss/v3.1/specification-document>
- Common Weakness Enumeration (CWE) -- <https://cwe.mitre.org/>
- CVE Program -- <https://www.cve.org/>